Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 5. El profesional de la seguridad de la información

Índice

Esquema

Ideas clave

5.1. Introducción y objetivos

5.2. La seguridad de la información como profesión

5.3. Retos y estrategias: la respuesta ante incidentes y la gestión de los nuevos entornos

5.4. Funciones y tareas del profesional de la seguridad de la información

5.5. Certificaciones profesionales

A fondo

Cyber Security Education, Qualifications and Training

Web de la organización (ISC)2

Hacking ético

The CISSP Prep Guide — Gold Edition

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

5.1. Introducción y objetivos

El objetivo fundamental de este tema es el de **conocer las principales funciones del profesional de la seguridad de la información, así como las competencias requeridas** para el correcto desempeño de sus tareas explicadas a través de diferentes certificaciones relacionadas con la profesión.

Este conocimiento es esencial para comprender los conceptos que son necesarios para convertirse en un profesional en el área.

Más concretamente, los objetivos de este tema son los siguientes:

- Entender y saber explicar el **rol del profesional** de la seguridad de la información en referencia al reconocimiento de la profesión por los clientes, el entorno académico y los conocimientos comúnmente requeridos.
- Comprender y saber explicar el rol del ***hacker* ético** dentro del contexto de la seguridad de la información.
- Adquirir los conocimientos necesarios para explicar las **funciones típicas de un profesional** de la seguridad de la información, así como los diferentes proyectos y tareas en las que se ve frecuentemente involucrado.
- Conocer las **certificaciones** fundamentales en el área de la seguridad de la información y entender el proceso de certificación.

Este tema trata de introducirte en el mundo profesional de la seguridad de la información. Como tal, lo que se pretende es que obtengas una visión general de algunas de las competencias que debe desarrollar el profesional de la seguridad de la información y, a la vez, conozcas las funciones, tareas y proyectos en las que tal profesional puede verse involucrada. En la unidad se introducen algunas de ellas, pero debes complementarlas con lecturas y búsquedas de información adicionales

© Universidad Internacional de La Rioja (UNIR)

para tener una visión completa de qué implica llegar a ser un profesional de la seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

5.2. La seguridad de la información como profesión

Una profesión puede caracterizarse por el desarrollo de los siguientes cinco criterios:

- La creación de un cuerpo organizado de conocimientos.
- el reconocimiento por parte de los clientes de la autoridad de la profesión.
- la aprobación de la Comunidad de la autoridad de la profesión.
- un código de ética.
- una cultura profesional apoyada por actividades académicas y profesionales.

Si miramos a la seguridad de la información, aunque no existe una carrera de Grado específica para la misma, sí se ha desarrollado claramente como disciplina independiente.

Aunque no hay una asociación profesional de clara aceptación general, **el cuerpo de conocimiento** *(body of knowledge, BOK)* **del consorcio (ISC)2** es un ejemplo de recopilación de requisitos en el área que puede considerarse como definitorio de qué debe saber un profesional de la seguridad de la información. También el (ISC)2 incluye en sus requisitos un código ético al que los certificados por la organización deben adherirse.

El **reconocimiento de la profesión** por la comunidad y los clientes parece más que evidente por la existencia de consultoras y empresas especializadas. Desde el punto de vista académico, existen conferencias académicas especializadas. También hay conferencias y eventos profesionales no específicos del ámbito académico.

© Universidad Internacional de La Rioja (UNIR)

Eventos especializados

Desde el punto de vista académico un ejemplo de evento especializado sería la conferencia ACM Conference on Computer and Communication Security (CCS) (https://ww.sigsac.org/css.html) que se celebra desde 1993, organizado por el grupo de interés SIGSAC (Security, Audit and Control) de ACM.

Además de las conferencias existen numerosas revistas especializadas:

IEEE Security and Privacy es un magacín técnico del IEEE. Como tal, los artículos publicados son breves. A pesar de quedar sometidos a evaluación por pares *(peer review),* los originales según la política editorial «en general no son adecuados para su publicación los artículos que cubren un área técnica muy particular». Para estos artículos que no encajan, se nos sugieren otras revistas de IEEE más orientadas a la investigación. Por ejemplo, la IEEE Transactions on Secure and Dependable Systems.

¿El *hacker* como profesional?

Existe mucha confusión sobre el término hacker y la connotación peyorativa que a veces se le ha asignado. Sin entrar en discusiones terminológicas, es importante resaltar que actualmente existe un concepto de ***hacking* ético** que implica el **análisis de vulnerabilidades de sistemas** mediante acciones ofensivas, pero **excluyendo los motivos maliciosos o espurios.** Por ello, el hacker ético actúa en coordinación con las empresas, que utilizan sus servicios para mejorar su seguridad.

E l *hacker* ético es un profesional con unas capacidades muy concretas que normalmente realiza la *penetration testing* de manera controlada y previo contrato o acuerdo con la empresa. La perspectiva de hacking ético tiene como elemento

© Universidad Internacional de La Rioja (UNIR)

interesante el situar la seguridad desde el contexto del atacante.

> Los eventos relacionados con el hacking son diferentes de las conferencias académicas
>
> Ejemplos de estos eventos son:
>
> El evento DefCon (https://www.defcon.org/)
>
> HackerHalted (http://www.hackerhalted.com/)
>
> Rooted CON (http://www.rootedcon.es/)
>
> En estos eventos se diseminan las técnicas y vulnerabilidades de seguridad que se encuentran en la práctica, las cuales pueden utilizarse de manera maliciosa o ética, aunque realmente las técnicas son las mismas, es la intención o el uso las que las diferencia.

© Universidad Internacional de La Rioja (UNIR)

5.3. Retos y estrategias: la respuesta ante incidentes y la gestión de los nuevos entornos

El profesional de la seguridad de la información se debe enfrentar a nuevos y mayores retos a medida que la tecnología avanza, las amenazas evolucionan, los perímetros tradicionales desaparecen y los entornos se vuelven cada vez más heterogéneos. Mientras que hace no demasiado tiempo el control de un entorno corporativo homogéneo y delimitado era relativamente sencillo, actualmente la complejidad y los retos a los que se enfrenta la seguridad de la información hace que sea necesario establecer estrategias y criterios bien definidos para protegerse ante los nuevos escenarios.

Dos de los aspectos que mejor debe conocer un gestor de la seguridad, tienen que ver precisamente con este tema: la **gestión** y **respuesta** a incidentes de seguridad y las implicaciones que conlleva el hecho de introducir nuevos entornos y filosofías en el tratamiento de la información que llevan aparejado la aparición de riesgos que eran inexistentes anteriormente.

Gestión de incidentes de seguridad

Un **incidente** de seguridad es un **evento no deseado** con alta probabilidad de **comprometer** las operaciones de la entidad **y amenazar** una o varias de las tres **dimensiones de la seguridad de la información: confidencialidad, disponibilidad e integridad.**

Algunos ejemplos de incidentes de seguridad:

- Incidentes que afecten a información sensible: datos personales, información clasificada, etc.
- Campañas de *malware.*

© Universidad Internacional de La Rioja (UNIR)

- Parada de procesos y servicios críticos.
- Exfiltración de datos.
- Sistemas comprometidos.
- Suplantación de identidad.

Hay diversas taxonomías de incidentes de seguridad y *frameworks* que desarrollan metodologías para hacer frente a los mismos. A continuación, puedes encontrar dos guías como referencias que te permitirán profundizar en el tema:

Guía CCN-STIC 817 Gestión de ciberincidentes: https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/988-ccn-stic-817-gestion-de-ciberincidentes/file.html

NIST SP 800-61 r2: Computer Security Incident Handling Guide https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf

La respuesta a incidentes es un proceso que permite a una organización estar preparada para responder a un incidente de seguridad de forma ágil, adecuada y sistemática. Las fases de este proceso son:

1. Definición de un plan que regule cómo se debe gestionar los diferentes tipos de incidentes de seguridad de acuerdo con su criticidad y categoría

- Definición de una taxonomía de incidentes.
- Definición de una estrategia a seguir por cada tipo de incidente.
- Asignación de los correspondiente roles y responsabilidades necesarios.
- Definición de un plan de comunicación.

© Universidad Internacional de La Rioja (UNIR)

2. Poner en marcha medidas de detección, análisis e investigación que permitan a la organización identificar incidentes en una fase temprana y evaluar su naturaleza

- Análisis de los potenciales incidentes y validación de estos.
- Asignación de una criticidad en función de su magnitud, escalándolo rápidamente si fuera necesario.

3. Definir los procedimientos necesarios para mitigar y contener un incidente y permitir la vuelta a la normalidad cuanto antes

Mitigar	▸ Activar el plan de respuesta para el tipo de incidente en cuestión.
	▸ Notificar e involucrar a las partes necesarias.
	▸ Documentar las acciones tomadas y la evolución del incidente.
	▸ Gestionar las comunicaciones.
Erradicar	▸ Identificar la causa raíz del incidente.
	▸ Identificar la mejor solución al problema y ponerla en práctica.
	▸ Documentar las acciones tomadas y la evolución del incidente.
Recuperación	▸ Aumentar las medidas de protección y las defensas.
	▸ Restablecer las operaciones.
	▸ Validar con los propietarios y partes interesadas que la vuelta a la normalidad es efectiva.

Tabla 1. Procedimientos para mitigar y contener un incidente. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

4. Tras controlar el incidente, se deberá realizar una investigación con sus respectivas conclusiones que permitan analizar sus causas y proponer acciones correctivas que prevengan otros incidentes similares en el futuro

- Elaborar un informe del incidente.
- Analizar los problemas y proponer acciones de mejora.
- Enviar dicho informe a las partes interesadas.
- Realizar seguimiento de la implantación y eficacia de las nuevas medidas.

La gestión de la seguridad en los nuevos entornos

La aparición de nuevos escenarios que difieren enormemente del tradicional entorno corporativo, donde la organización tenía un perímetro bien delimitado y un buen control de los flujos de información, ha evolucionado y cambiado radicalmente con la irrupción de nuevos enfoques como el uso de la nube (SaaS, PaaS, IaaS, etc.), la movilidad con el uso de dispositivos móviles personales para acceder a recursos corporativos (BYOD) y el incremento del teletrabajo, el uso de las redes sociales por parte de los empleados (en calidad de tales) y muchas otras.

Por su importancia y rápido crecimiento en los últimos años, es importante conocer en profundidad sus propios riesgos inherentes y cómo se deberían gestionar. A continuación, se mostrarán varias directrices fundamentales para tener en cuenta en algunos de estos nuevos entonos.

© Universidad Internacional de La Rioja (UNIR)

La nube

La computación en la nube es una forma atractiva para las empresas de poder ahorrar costes o agilizar procesos en ciertos escenarios. No obstante, entraña a su vez un conjunto de riesgos que se deben tener en cuenta. Entre ellos:

- Pérdida de control sobre la gestión de la seguridad.
- El grado de adecuamiento a determinadas estándares, leyes y normativa queda supeditado al alineamiento que tenga el proveedor a las mismas y a las evidencias que pueda aportar para demostrarlo.
- Posible incremento en el grado de exposición al abrir una puerta en el exterior para la gestión y consumo del servicio que antes estaba solo accesible internamente.
- En las nubes que nos son privadas, es decir, que comparten elementos de su infraestructura entre diferentes clientes, aparece el riesgo de que se produzcan fallos de aislamiento.

Algunas de las medidas que se pueden tomar para reducir y gestionar estos riesgos son:

- Desarrollar y poner en marcha políticas y estándares corporativos que definan requisitos concretos a exigir en las licitaciones relacionadas con servicios en la nube.
- Establecer auditorías, informes de auditoría de terceros de confianza o, llegado el caso, incluso exigir el derecho de auditoria para verificar que se siguen las políticas de la organización.
- Analizar el alcance y el impacto de las leyes y regulaciones en los entornos de la nube para escoger la mejor estrategia en función de la criticidad de la información a la que accederá el proveedor.
- Incorporar y negociar en los contratos de los proveedores todas las cuestiones

© Universidad Internacional de La Rioja (UNIR)

relevantes acerca de la seguridad de la información mediante la especificación de los procesos, SLAs y clausulas pertinentes: continuidad, respuesta ante incidentes, parcheado, gestión de los datos personales, mecanismos de control de acceso, seguridad física, criptografía, etc. Es recomendable tomar como referencia un *framework* o estándar relevante para asegurar que se tienen en cuenta todos los dominios y puntos clave.

- Analizar las tecnologías utilizadas por el proveedor, hasta donde sea posible, para evaluar su idoneidad.

Para profundizar en otros aspectos relacionados con la gestión de la seguridad en la nube, se puede recurrir a organizaciones como CSA, Cloud Security Alliance, que promueven el uso de las mejores prácticas en estos entornos.

Accede a la página oficial de este sistema a través del siguiente enlace: https://cloudsecurityalliance.org

---

Movilidad

El uso de dispositivos móviles, si bien representa una herramienta eficaz y productiva, lleva aparejados para el gestor de la seguridad entre otras muchas preocupaciones las siguientes:

- Mayor riesgo de pérdida o robo al ser un dispositivo pensado para su uso itinerante y al ser de un tamaño reducido.
- Mayor complejidad, tanto legal como técnica, al implantar políticas de seguridad y al proteger la información contenida en estos dispositivos sobre todo si son propiedad del trabajador y no de la empresa.
- Posible incremento de la complejidad al tener que gestionar un parqué de movilidad heterogéneo con fabricantes y modelos diversos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- La cada vez mayor capacidad de los terminales móviles lleva aparejada a su vez un incremento de las potenciales amenazas y los posibles vectores de ataque que podría utilizar un atacante.

Las buenas prácticas recomiendan que para gestionar adecuadamente estos riesgos se debe permitir solo el acceso a la información corporativa únicamente desde dispositivos controlados mediante *software* específico que garantice unas determinadas configuraciones de seguridad: autenticación robusta, evitar aplicaciones no confiables, cifrado, geolocalización en caso de robo, bloqueo y borrado remoto, contenedor corporativo aislado, etc.

Si esto no fuese posible, como mínimo, se debe garantiza, tanto con medidas normativas (cláusulas de buen uso, etc.) como con las medidas técnicas que sea posible aplicar o requerir (catálogo de modelos admitidos, configuración mínima exigible, etc.), que el dispositivo es apto para ser utilizado para acceder a los datos y recursos de la empresa.

© Universidad Internacional de La Rioja (UNIR)

5.4. Funciones y tareas del profesional de la seguridad de la información

La seguridad de la información es un concepto muy amplio que abarca múltiples puntos de vista. Esto conlleva que el profesional de la seguridad de la información pueda desarrollar un sinfín de tareas y actividades que, si bien todas ellas tienen como denominador común la protección de la información, son muy diferentes entre sí.

La siguiente lista no pretende ser una enumeración exhaustiva de los diferentes proyectos en los que se pueden ver involucrados estos profesionales ni de los cometidos que llevan a cabo, pero es una buena aproximación para que conozcas lo que solicita actualmente el mercado.

Hay que tener en cuenta también que la taxonomía para los proyectos, servicios, tareas o actividades en relación con la seguridad de la información no es única, pudiéndose ubicar a algunas de las actividades en diferentes categorías, por lo que únicamente se debe tener en cuenta como una clasificación más pudiendo existir otras.

Auditoría técnica

Proyectos de marcado carácter técnico que permiten **analizar y diagnosticar el nivel real de seguridad** de forma global o respecto a un campo específico de la seguridad. Hay una gran diversidad de posibles proyectos de revisión que se podrían tener en cuenta:

- ***Hacking* ético:** analiza los activos tecnológicos de una organización con el fin de encontrar vulnerabilidades en los mismos.
- ***Test* de intrusión:** simula el comportamiento de un atacante para comprometer un sistema expuesto al exterior.

© Universidad Internacional de La Rioja (UNIR)

- **Análisis forense:** investigación acerca de las causas de un incidente de seguridad.
- **Análisis de *malware:*** análisis del comportamiento de ficheros, sistemas, páginas web y en general cualquier entidad que pudiera contener o propagar malware.
- **Análisis de vulnerabilidades:** identificación de los puntos débiles de un sistema, red o aplicación.
- **Revisión de código:** análisis de la robustez de un código desde el punto de vista de seguridad. Puede conllevar análisis de vulnerabilidades, análisis estático y dinámico del código, etc.

Cumplimiento

Esta categoría incluye aquellos proyectos relacionados con la gestión de los riesgos y de la adecuación del cumplimiento normativo en materia de seguridad.

- **Certificación:** definición e implantación de los controles necesarios, así como del cuerpo normativo y de los demás objetivos necesarios para la adecuación a una normativa o estándar o la certificación de acuerdo con sus criterios (Por ejemplo, ISO 27001).
- **Análisis y gestión de riesgos:** identificación y gestión de los riesgos que se ciernen sobre una organización.
- **Desarrollo del cuerpo normativo:** definición, desarrollo y mantenimiento del cuerpo normativo relacionado con la seguridad de información (Por ejemplo, políticas, estándares, normas, procedimientos, líneas base, etc.).
- **Cumplimiento legal:** identificación de la regulación con aplicación en la entidad y control para lograr cumplir sus requisitos (Por ejemplo, LOPD, PCI DSS, etc.).

© Universidad Internacional de La Rioja (UNIR)

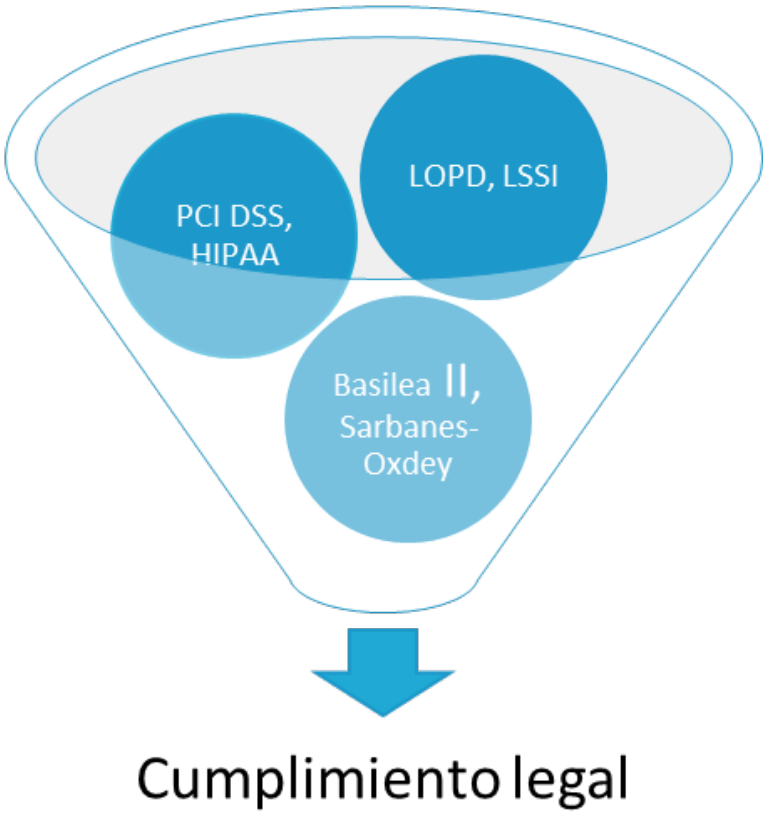


Figura 1. Cumplimiento legal. Fuente: elaboración propia.

- **Auditoría:** contraparte del punto anterior con el objetivo de identificar aquellos puntos no conformes con la regulación o con la normativa interna.
- **Requisitos de seguridad en nuevas iniciativas:** identificación de riesgos para la seguridad de la información en las nuevas iniciativas de una entidad con el fin de mitigarlos mediante la definición de requisitos de seguridad.
- **Evaluación de la seguridad:** definición de métricas y cuadros de mando para conocer el estado de la seguridad en una organización. También incluiría iniciativas destinadas a conocer el estado de la seguridad de forma global con el fin de llegar a un nivel de seguridad superior (Por ejemplo, el Plan Director de Seguridad).

© Universidad Internacional de La Rioja (UNIR)

Resiliencia

Esta categoría incluye aquellas actividades encaminadas a garantizar la disponibilidad de la información y la gestión de una contingencia grave que pudiera afectar a la organización y sus activos.

- **Planes de continuidad (BCP):** aseguran la continuidad de los procesos críticos de negocio tras un desastre en un periodo de tiempo asumible para la organización.
- **Planes de recuperación (DRP):** forman parte del BCP y tratan de garantizar la continuidad de los servicios y aplicaciones críticos para el negocio que tengan soporte tecnológico en un periodo de tiempo asumible para la organización.
- **Gestión de crisis:** también forman parte de una BCP e incluye la definición de los aspectos relevantes acerca de cómo reaccionar ante una crisis y la formación a la Dirección y a los actores relevantes en las tareas de gestión de esta.

Formación y concienciación

Diseño del plan de formación en una entidad, asignación de cursos y certificaciones al personal en función de su rol y responsabilidad, realización de campañas de concienciación y sensibilización, proveer formación continua en asuntos relevantes relacionados con la seguridad, etc.

Gestión de incidentes

Definir, implantar y mejorar las tareas relacionadas con la prevención, detección y respuesta ante incidentes de seguridad.

© Universidad Internacional de La Rioja (UNIR)

Despliegue de soluciones de seguridad

En este apartado se pueden incluir muchas de las otras categorías. Un ejemplo sería el análisis, diseño e implantación de soluciones como:

- **Accesibilidad:** herramienta para el control de acceso a la red (NAC), de gestión de identidades privilegiadas, uso de firma electrónica, biometría, certificados…
- **Control de la información:** despliegue de soluciones para la prevención de fugas de información (DLP) o gestión de los derechos de la información (IRM).
- **Movilidad:** Soluciones para la gestión del parque móvil y su seguridad (soluciones MDM).
- Otras herramientas y soluciones.

Seguridad en la nube

Análisis y supervisión de la seguridad de la información en entornos *cloud* o en la nube (SaaS, PaaS, IaaS...), identificando y gestionando riesgos, implantando controles, imponiendo requisitos, etc. Es una categoría que engloba muchas de las otras, pero por su especial relevancia se puede considerar como una propia.

Operación de la seguridad

Esta categoría abarca todas aquellas actividades relacionadas con la seguridad gestionada, el *outsourcing* o los Centros de Operaciones de Seguridad (SOC), en los cuales, independientemente de la forma en la que se preste el servicio o tarea, es un tercero el que opera la seguridad de una organización.

Seguridad física/patrimonial

La seguridad física de los activos es clave para proteger la información. Tareas como los *test* de intrusión físicos, la auditoria o la seguridad integral (combinación del mundo de la seguridad física y lógica para buscar convergencias que puedan beneficiar a la organización) forman parte de esta categoría.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Protección de Infraestructura Critica

La seguridad de la información aplicada en entornos críticos para la sociedad (centrales termoeléctricas, hospitales, sector financiero…) con regulaciones y requisitos muy concretos.

Seguridad industrial

Al igual que la categoría anterior, aquí se incluyen los proyectos y tareas relacionados con la aplicación de la seguridad en entornos automáticos e industriales, con requisitos y necesidades muy diferentes a los aplicados tradicionalmente en IT. Ejemplos en esta categoría son las revisiones de SCADAs y otros sistemas de control industrial (ICS).

Oficinas técnicas

Conocidas con este nombre u otros similares, son muy habituales en entidades con un nivel de seguridad aun poco maduro y que externaliza el área de seguridad (total o parcialmente) en un tercero. Aunque es una forma de *outsoucing,* la mayor implicación de una Oficina de seguridad en la estrategia y planificación de la seguridad hace que pueda considerar una categoría aparte.

Inteligencia de seguridad

Áreas como la detección de fraude o la detección de amenazas, se benefician de técnicas de correlación de eventos o del *big data,* siendo capaces de crear inteligencia y encontrar patrones a partir de fuentes como los eventos de seguridad.

Protección de las comunicaciones

Esta categoría engloba todas aquellas tareas relacionadas con la mitigación de riesgos en las comunicaciones mediante el análisis de las redes y la electrónica de red. Incluye la supervisión y configuración de cortafuegos, VPNs, IDSs, IPSs, balanceadores, …

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El responsable de la ciberseguridad

La toma de conciencia en seguridad de la información ha provocado que multitud de empresas hayan tomado la decisión de nombrar a un responsable de la ciberseguridad en sus organizaciones.

En muchas ocasiones, este nombramiento recae en alguien de la propia entidad que, aunque con años de trayectoria en IT, no cuenta con experiencia en seguridad de la información. Son muchos los desafíos que en este caso (u otros similares), se deben afrontar debiendo poner en marcha las iniciativas y proyectos necesarios para gestionar adecuadamente los riesgos que se ciernen sobre la información de una organización.

En el siguiente enlace, puedes acceder a un documento de SANS que trata esta situación y que describe los pasos a seguir para lograr el éxito:

https://www.sans.org/reading-room/whitepapers/infosec/information-security-starting-33239

© Universidad Internacional de La Rioja (UNIR)

5.5. Certificaciones profesionales

Existen multitud de certificaciones, cursos y títulos en el mercado con diferentes fines y objetivos. Mientras unos están enfocados al área de gestión de la seguridad, otros, sin embargo, tienen como meta conocer y mejorar las habilidades técnicas en una determinada metodología, herramienta o área específica de la seguridad. Existe también un tercer grupo en el que se pueden englobar aquellas certificaciones en un estado intermedio entre el ámbito de gestión y técnico.

Debido al amplio abanico de posibilidades, será el profesional de la seguridad de la información el que, en función de sus intereses y motivaciones, deba elegir que conocimiento desea desarrollar en mayor profundidad.

Si bien es cierto que hay otras formas de adquirir este conocimiento (experiencia, cursos de postgrado…), las certificaciones han llegado a tener un campo muy relevante en el campo de IT y concretamente en el de la seguridad de la información.

Algunos de los motivos que han favorecido esta situación son los siguientes:

- Alta especialización en el sector.
- Necesidad de demostrar determinados conocimientos ante clientes o empleadores.
- Los cambios tan rápidos en la tecnología conllevan una necesidad continua de reciclaje y actualización de conocimientos.

Lo mismo sucede con la pertenencia a las organizaciones que llevan a delante estos programas -–ISACA, (ISC)2, EC-Council, GIAC…– resultando hoy en día actores muy relevantes en el sector y fomentando el intercambio de ideas, la formación continua y la creación de una comunidad de seguridad de la información.

Algunos ejemplos de certificaciones internacionalmente reconocidas son CISA,

© Universidad Internacional de La Rioja (UNIR)

CISM, CISSP, CEH, ISO 27001 LI, Security +, OSCP, GCIH, CCNA Security…

Debido a la infinidad de certificaciones que hay se han tomado tres generalistas a modo de ejemplo, dos pertenecientes a $(ISC)^2$ y una a ISACA.

Certificaciones $(ISC)^2$

E l **Consorcio internacional de Certificación de Seguridad de Sistemas de Información** o (ISC)2 (International Information Systems Security Certification Consortium), fundado en 1989, es una organización sin ánimo de lucro con sede en Florida, dedicada fundamentalmente a la formación y certificación en seguridad de la información.

Las certificaciones $(ISC)^2$ incluyen:

- Certified Information Systems Security Professional (CISSP), que consta de:
  - Information Systems Security Architecture Professional (CISSP-ISSAP).
  - Information Systems Security Engineering Professional (CISSP-ISSEP).
  - Information Systems Security Management Professional (CISSP-ISSMP).
- Certified Secure Software Lifecycle Professional (CSSLP).
- Certification and Accreditation Professional (CAP).
- Systems Security Certified Practitioner (SSCP).

Probablemente la más conocida y extendida de todas ellas es el **CISSP,** que es una certificación profesional generalista muy amplia.

Certificación CISSP de $(ISC)^2$

La certificación CISSP es una de las más valoradas por su reconocimiento internacional. Un CISSP está certificado como profesional para «definir la

© Universidad Internacional de La Rioja (UNIR)

arquitectura, diseño, gestión y controles de los sistemas empresariales».

Los **certificados,** además de contar con un valor añadido para su contratación, forman parte de la comunidad de (ISC)2, donde pueden actualizarse y tener oportunidades adicionales para interactuar con sus colegas.

El CISSP se estructura en ocho dominios desde el año 2015 (previamente eran diez) que conforman el Common Body of Knowledge (CBK):

- Gestión del riesgo y la seguridad *(Security and Risk Management).*
- Seguridad de los activos *(Asset Security).*
- Ingeniería de seguridad *(Security Engineering).*
- Seguridad en redes y comunicaciones *(Communications and Network Security).*
- Gestión de accesos e identidades *(Identity and Access Management).*
- Pruebas y evaluación de la seguridad *(Security Assessment and Testing).*
- Operaciones de seguridad *(Security Operations).*
- Seguridad en el desarrollo de *software (Software Development Security).*

Para la certificación CISSP se deben cumplir los siguientes requisitos:

- **Aprobar el examen CISSP:** consta de 250 preguntas de selección simple con seis horas de duración.
- Demostrar **experiencia mínima de cinco años** en al menos dos de los diez dominios del CBK.
- Adherirse al **Código Ético de la ISC2.**

Para mantener la certificación CISSP se debe realizar una cierta cantidad de **actividades,** cuya finalidad **es asegurar que el profesional se ha mantenido**

© Universidad Internacional de La Rioja (UNIR)

activo en el área de la seguridad a lo largo del tiempo. Cada una de estas actividades recibe cierta cantidad de créditos (CPE) de los cuales el profesional debe reunir 120 cada tres años.

Certificación CAP de (ISC)^2

La certificación CAP (Certified Authorization Professional) se dirige a **certificar los conocimientos, las habilidades y las capacidades que necesitan los profesionales** que evalúan riesgos y establecen parámetros de seguridad para contrarrestar los riesgos potenciales. Se ha preparado con la colaboración de la Oficina de Seguridad de la Información del Departamento de Estado de los EE. UU.

Esta certificación se centra en los siguientes dominios:

- Entender la autorización de seguridad de sistemas de información.
- Categorizar los sistemas de información.
- Establecer la línea de base de control de seguridad.
- Aplicar controles de seguridad.
- Evaluar los controles de seguridad.
- Autorizar sistemas de información.
- Monitorizar los controles de seguridad.

Certificaciones ISACA

La **Asociación de Auditoría y Control de Sistemas de Información** o ISACA por sus siglas en inglés, fue establecida en 1969, siendo una asociación global sin ánimo de lucro de 140 000 profesionales en 180 países que apoya el desarrollo de metodologías y certificaciones en el área de auditoría y control de sistemas de información.

© Universidad Internacional de La Rioja (UNIR)

Las certificaciones de ISACA incluyen:

- Certified Information Systems Auditor (CISA).
- Certified Information Security Manager (CISM).
- Certified in the Governance of Enterprise IT (CGEIT).
- Certified in Risk and Information Systems Control (CRISC).

Adicionalmente desarrolla el programa CSX y el *framework* COBIT para el gobierno y la gestión de IT entre otras importantes iniciativas.

La certificación CISM de ISACA

La Information Systems Audit and Control Association (ISACA, Asociación de Auditoría y Control de Sistemas de Información), es una asociación internacional fundada en 1967 que **promueve y organiza el desarrollo de metodologías y certificaciones para las actividades auditoría y control** en sistemas de información. Entre sus productos más conocidos está el *framework* COBIT de control de sistemas de información o las certificaciones de auditoría.

ISACA ofrece también el Certified Information Security Manager (CISM o Gestor Certificado en Seguridad de la Información), dirigido específicamente al área de gestión en el contexto de la seguridad.

Los **dominios** que cubre CISM son los siguientes:

- Gobierno de seguridad de la información.
- Gestión de riesgos de información y cumplimiento.
- Desarrollo y gestión del programa de seguridad de la información.
- Gestión de incidentes de seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El proceso de certificación tiene bastantes puntos en común con el de CISSP, concretamente los pasos son los siguientes:

- Aprobar el examen CISM.
- Adherirse al Código de Ética Profesional de ISACA.
- Estar de acuerdo en cumplir con la Política de Educación Continua.
- Acreditar experiencia laboral en el ámbito de la seguridad de la información.
- Presentar una solicitud de certificación CISM.

© Universidad Internacional de La Rioja (UNIR)

Cyber Security Education, Qualifications and Training

Martin, K. (2015, abril 10). Cyber Security Education, Qualifications and Training [Versión posterior a publicación]. *Engineering & Technology Reference.* https://pure.royalholloway.ac.uk/portal/files/25218802/IETEducationTraining.pdf

El profesor Keith M. Martin repasa a través del siguiente trabajo académico las diferentes posibilidades para adquirir y desarrollar conocimientos y habilidades relacionadas con la ciberseguridad. Aunque el punto de vista del autor se centra sobre todo en el mercado británico, la mayor parte de los criterios que se deben tener en cuenta a la hora de elegir un programa de esta índole son generalizables.

© Universidad Internacional de La Rioja (UNIR)

Web de la organización (ISC)2

Web de la organización (ISC)^2.

(ISC)^2 es la organización dedicada a la certificación de los profesionales de la seguridad que soporta la certificación CISSP. En su Web se pueden encontrar los detalles de las diferentes certificaciones, enlaces a los materiales oficiales de preparación de los exámenes y también algunos recursos introductorios a los diferentes dominios de las certificaciones.

© Universidad Internacional de La Rioja (UNIR)

Hacking ético

Tori, C. (2008). *Hacking Ético*. El autor. https://nebul4ck.files.wordpress.com/2015/08/hacking-etico-carlos-tori.pdf

En este libro gratuito, el autor expone las principales técnicas y fuentes de información para el denominado hacking ético, que no es otra cosa que la intrusión proactiva en los sistemas sin intención maliciosa y mediando el consentimiento. El libro es gratuito.

© Universidad Internacional de La Rioja (UNIR)

The CISSP Prep Guide — Gold Edition

Krutz, R. y Vines, R. (2002). *The CISSP Prep Guide Gold Edition.* Wiley.

Hay numerosos libros para la preparación del examen CISSP –además de la propia guía del $(ISC)^2$–. Estas guías habitualmente se estructuran de acuerdo con los dominios de la certificación e incluyen preguntas de *test* similares a las del examen con diferentes niveles de dificultad.

© Universidad Internacional de La Rioja (UNIR)

1. Indica cuáles de las siguientes afirmaciones respecto a los *hackers* éticos son ciertas:

A. No forman parte activa de la comunidad de la seguridad de la información.

B. Pueden actuar al margen de la ley siempre que su fin no sea malicioso.

C. Todos los *hackers* utilizan técnicas similares, pero los así denominados se basan en un código ético.

D. Ninguna de las anteriores.

2. Indica cuáles de las siguientes tareas relativas al profesional de la seguridad de la información no se podrían encuadrar en el ámbito de la resiliencia:

A. La supervisión de los procedimientos técnicos de restauración para levantar la infraestructura IT en caso de disrupción.

B. El diseño de las estrategias de recuperación de las diferentes aplicaciones de negocio.

C. La operación de los sistemas del CPD de contingencia en caso de quedar inutilizado el *datacenter* principal.

D. El análisis de la replicación de los datos entre el CPD principal y el secundario de una organización.

3. ¿Cuáles de las siguientes propuestas se podrían poner en marcha en una organización para favorecer la seguridad integral:

A. Reportar los incidentes de seguridad, tanto las áreas de seguridad física como de seguridad lógica, de forma centralizada a la Alga Gerencia de la compañía.

B. Crear un único departamento de seguridad (tanto física como lógica) en la entidad, bajo un solo responsable y sin tener en cuenta especializaciones, para favorecer la homogeneización de los empleados.

C. Creación de un *framework* corporativo de seguridad integral que permita dar una respuesta a los riesgos de forma convergente.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

4. ¿Cuál podría ser el objetivo de realizar un *test* de intrusión sobre la infraestructura tecnológica de una central nuclear?

A. Evaluar la eficacia de las medidas de seguridad que el operador adoptó para proteger la central de acuerdo con la legislación vigente respecto a la protección de infraestructura críticas.

B. Certificar la correcta implantación de un Sistema de Gestión de la Seguridad de la Información en la entidad.

C. Definir los responsables de seguridad de un sistema de control industrial.

D. Analizar la capacidad de resiliencia con la que cuenta la planta nuclear.

5. En relación con el área de cumplimiento, ¿qué tipo de tareas podría llevar a cabo el profesional de la seguridad de la información?

A. Revisar si la empresa subcontratada para limpiar las salas y despachos de la entidad ha firmado un acuerdo de confidencialidad.

B. Identificar todas las normativas y regulaciones vigentes con aplicación en la organización.

C. Asegurar la coherencia de todo el cuerpo normativo de seguridad en la entidad, identificando posibles inconsistencias.

D. Todas las anteriores.

6. ¿Qué aspectos de los siguientes son una muestra del reconocimiento de la seguridad de la información como profesión?

A. La existencia de estándares de seguridad relacionados con el sector.

B. El número cada vez más elevado de ataques contra empresas y entidades a lo largo de todo el mundo.

C. La gran cantidad de títulos, certificaciones y programas específicos en seguridad de la información disponibles en el mercado.

D. Ninguna de las anteriores.

7. Indica cuáles de las siguientes afirmaciones son ciertas:

A. Las certificaciones como el CISSP determinan el acceso al ejercicio de la profesión dentro del área de la seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

B. La profesión de la seguridad de la información cuenta con cuerpos de conocimiento definidos y una cultura profesional como otras profesiones diferenciadas.

C. El código ético del profesional de la información es el definido en las normas de auditoría ISO 27001.

D. Ninguna de las anteriores.

8. Indica cuáles de las siguientes afirmaciones son correctas:

A. Las revistas académicas del área de la seguridad de la información son el principal medio de formación básica para los profesionales de la seguridad de la información.

B. Se llama hacker ético a cualquier profesional de la seguridad de la información.

C. Un hacker ético puede realizar acciones de *penetration testing* contra una empresa siempre que no perciba beneficios económicos por ello.

D. Ninguna de las anteriores.

9. Indica cuáles de las áreas o conocimientos están incluidas de forma explícita en la certificación CISSP:

A. La seguridad física de los sistemas.

B. La regulación sobre la protección de datos.

C. El desarrollo de software seguro.

D. Todas las anteriores.

10. Indica cuáles de las siguientes afirmaciones son ciertas sobre las certificaciones de seguridad de la información:

A. La certificación CAP tiene un contenido técnico equivalente a la certificación CISSP.

B. Las certificaciones son títulos como las titulaciones que se obtienen y no necesitan renovarse.

C. La certificación CISSP solo puede obtenerse cuando se tiene experiencia profesional en el área.

© Universidad Internacional de La Rioja (UNIR)

D. Ninguna de las anteriores.

3. ¿Cuáles de las siguientes propuestas se podrían poner en marcha en una organización para favorecer la seguridad integral

A. Reportar los incidentes de seguridad, tanto las áreas de seguridad física como de seguridad lógica, de forma centralizada a la Alga Gerencia de la compañía.

B. Crear un único departamento de seguridad (tanto física como lógica) en la entidad, bajo un solo responsable y sin tener en cuenta especializaciones, para favorecer la homogeneización de los empleados.

C. Creación de un *framework* corporativo de seguridad integral que permita dar una respuesta a los riesgos de forma convergente.

D. Ninguna de las anteriores.

4. ¿Cuál podría ser el objetivo de realizar un *test* de intrusión sobre la infraestructura tecnológica de una central nuclear?

A. Evaluar la eficacia de las medidas de seguridad que el operador adoptó para proteger la central de acuerdo con la legislación vigente respecto a la protección de infraestructura críticas.

B. Certificar la correcta implantación de un Sistema de Gestión de la Seguridad de la Información en la entidad.

C. Definir los responsables de seguridad de un sistema de control industrial.

D. Analizar la capacidad de resiliencia con la que cuenta la planta nuclear.

© Universidad Internacional de La Rioja (UNIR)

5. En relación con el área de cumplimiento, ¿qué tipo de tareas podría llevar a cabo el profesional de la seguridad de la información?

A. Revisar si la empresa subcontratada para limpiar las salas y despachos de la entidad ha firmado un acuerdo de confidencialidad.

B. Identificar todas las normativas y regulaciones vigentes con aplicación en la organización.

C. Asegurar la coherencia de todo el cuerpo normativo de seguridad en la entidad, identificando posibles inconsistencias.

D. Todas las anteriores.

6. ¿Qué aspectos de los siguientes son una muestra del reconocimiento de la seguridad de la información como profesión?

A. La existencia de estándares de seguridad relacionados con el sector.

B. El número cada vez más elevado de ataques contra empresas y entidades a lo largo de todo el mundo.

C. La gran cantidad de títulos, certificaciones y programas específicos en seguridad de la información disponibles en el mercado.

D. Ninguna de las anteriores.

7. Indica cuáles de las siguientes afirmaciones son ciertas:

A. Las certificaciones como el CISSP determinan el acceso al ejercicio de la profesión dentro del área de la seguridad de la información.

B. La profesión de la seguridad de la información cuenta con cuerpos de conocimiento definidos y una cultura profesional como otras profesiones diferenciadas.

C. El código ético del profesional de la información es el definido en las normas de auditoría ISO 27001.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

8. Indica cuáles de las siguientes afirmaciones son correctas:

A. Las revistas académicas del área de la seguridad de la información son el principal medio de formación básica para los profesionales de la seguridad de la información.

B. Se llama hacker ético a cualquier profesional de la seguridad de la información.

C. Un hacker ético puede realizar acciones de *penetration testing* contra una empresa siempre que no perciba beneficios económicos por ello.

D. Ninguna de las anteriores.

9. Indica cuáles de las áreas o conocimientos están incluidas de forma explícita en la certificación CISSP:

A. La seguridad física de los sistemas.

B. La regulación sobre la protección de datos.

C. El desarrollo de software seguro.

D. Todas las anteriores.

10. Indica cuáles de las siguientes afirmaciones son ciertas sobre las certificaciones de seguridad de la información:

A. La certificación CAP tiene un contenido técnico equivalente a la certificación CISSP.

B. Las certificaciones son títulos como las titulaciones que se obtienen y no necesitan renovarse.

C. La certificación CISSP solo puede obtenerse cuando se tiene experiencia profesional en el área.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)